

PURPOSE

In accordance with the COSO 2013 Framework, when management identifies a report, whether it be from a system, an application (e.g., Microsoft Excel) or manually created, within the financial reporting process they must have assurance that there is integrity of the underlying data and that the information presented in the report is complete and accurate. This policy seeks to define how reports are to be identified, managed and controlled. Note that it is the responsibility of process owners to identify EAEs and apply the appropriate controls as discussed in the policy.

At Hilton Worldwide, reports relied upon for key SOX controls are referred to as Electronic Audit Evidence (“EAE”). The Company has bifurcated EAE into two groups referred to as “User Developed Applications” (“UDAs”) and “Reports and Data” (“RADs”) based on the nature of how the report is generated (i.e., manual versus automated) and its source system (i.e., Hyperion, Excel, etc.).

POLICY SUMMARY

Key EAEs, subject to this policy, are defined as being UDAs or RADs that are used to support key financial reporting activities noted within key SOX controls.

As key EAEs are identified, they must be included in the centralized inventory maintained by the SOX Project Management Office (SOX PMO) and appropriate controls must be identified and implemented to ensure the completeness and accuracy of relevant information, as well as the integrity of any underlying logic.

BACKGROUND / SCOPE

The effectiveness of key financial reporting activities depends on the integrity of the EAE supporting the activity. Therefore, controls over the reliability of EAEs are critical to support the integrity of the Company’s financial reporting process. Accordingly, management must identify and implement appropriate controls over EAEs.

Process Owners should consider the following qualitative factors when determining whether an EAE is key and subject to this policy:

Does the EAE support a SOX key control?

- Examples:
 - EAE supports a journal entry amount, coding, etc.
 - EAE supports disclosure amount in footnotes or other external reporting
 - EAE supports completeness and accuracy of another report used as part of a SOX control
 - SOX key control could not be performed (easily or sufficiently) without the EAE

User Developed Applications (UDAs)

UDAs consist primarily of internally developed MS Excel spreadsheets, MS Access databases, or other desktop database tools or applications (e.g., query / reporting tools) created and maintained by Process Owners.

- Examples:
 - MS Excel schedule use to calculate a journal entry amount (e.g., MS Excel schedule that computes the required A/R reserve based on the A/R aging)
 - MS Excel model used to perform an analysis that would have a financial reporting effect (e.g., MS Excel model used to perform an impairment analysis)

Reports and Data (RADs)

RADs are reports and data generally obtained directly from the Company’s systems (i.e., system-generated) or compiled from various data sources (i.e., manually-compiled).

System-generated RADs are generated in one of two ways:

- 1) Standard / out-of-the-box reports from an enterprise system (i.e., a system that is managed by IT and subject to IT General Controls) whereby the report coding / logic cannot be altered
- 2) Custom reports generated from a system

Examples of RADs include:

- Standard Report: A Fixed Asset GL detail report from PeopleSoft used by a Process Owner to support a SOX key control
- Custom System Report: A Payroll Change Report used by a Process Owner to support a SOX key control

Note: A system or application query may extract data from the source and present as an excel schedule. In this case, if the data in the excel schedule is modified and used to support a SOX key control, the report is considered a UDA.

APPLICABILITY

This policy applies to all Corporate, Owned & Leased Hotel Team Members responsible for maintaining key EAEs that affect the financial statements or footnote disclosures of the Company.

This policy does not apply to EAEs used to support activities that are not integral to a SOX process or SOX key control.

EXCLUSIONS / EXCEPTIONS

None

POLICY DETAILS

Process Owners are responsible for identifying key EAEs within their respective process areas and implementing appropriate controls to ensure there is integrity in the logic and relevant data contained in the EAE is complete and accurate. Control requirements for RADs and UDAs vary given the nature in which these types of EAEs are created and maintained. Control requirements for each EAE are dependent upon the classification (UDA or RAD), SOX coverage for RADs (In-Scope or Out-of-Scope), and prioritization level (as outlined below).

Prioritization

Once a RAD or UDA is identified as a key EAE, it is evaluated for prioritization. Prioritization of EAEs is based upon two overarching criteria which are then divided into six sub-criteria. These categories are as follows:

- 1) Significance -
 - 1) *Proximity to Financials* - How directly the EAE impacts a financial statement line item or disclosure
 - 2) *Materiality* - The dollar value impact an EAE may have on a financial statement line item or disclosure
- 2) Likelihood of Error -
 - 1) *Frequency of Use* - How often the EAE is utilized to perform a SOX key control
 - 2) *Frequency of Logic Change* - How often the EAE coding or logic is changed
 - 3) *Complexity* - The level of sophistication associated with the information and calculations within the EAE (i.e., macros and formulas)
 - 4) *Volume of Data and Transactions* - The volume of data processed by the EAE

Based upon responses to the above criteria, risk rankings are determined and weighted to produce an overall “Priority Score” for each EAE on a scale of 0-9.

The associated scores reflect the overall risk associated with the EAE (0 – Lowest, 9 – Highest). Risk levels and associated scores are as follows:

- *High*: Scores greater than 4.99
- *Medium*: Scores falling between 3.00 and 4.99
- *Low*: Scores of 2.99 and below

Note: Please see Appendix A: Prioritization Details for a table which cross-references Criteria to Responses and associated Risk Scores.

Control Applicability

Based on each EAE’s final risk level, the table below highlights associated controls Process Owners are responsible for:

	High	Medium	Low
Reports & Data (IT SOX systems) <i>Reports and/or Data generated from systems with effective IT General Controls</i>	➤ Automated Controls <i>Note: No Process Owner action required beyond execution of manual control for which EAE is produced</i>	➤ Automated Controls <i>Note: No Process Owner action required beyond execution of manual control for which EAE is produced</i>	As needed to validate basis for use in control <i>Note: Not validated by IA</i>
Reports & Data (non-IT SOX systems) <i>Reports and/or Data generated from systems without effective (or unsubstantiated) IT General Controls</i>	➤ Completeness & Accuracy ➤ Integrity & Logic	➤ Completeness & Accuracy ➤ Integrity & Logic	As needed to validate basis for use in control <i>Note: Not validated by IA</i>
UDAs <i>User Developed Applications (e.g., spreadsheets, MS Access databases)</i>	➤ Access Restriction ➤ Access Review ➤ Versioning ➤ Change Review ➤ Integrity & Logic ➤ Completeness & Accuracy ➤ Backups	➤ Access Restriction ➤ Access Review ➤ Integrity & Logic ➤ Completeness & Accuracy	As needed to validate basis for use in control <i>Note: Not validated by IA</i>

RESPONSIBILITIES

- **Process Owner:** Control Performance (w/ Related Evidence)
- **IA / External Audit:** Verification of Control Performance

Control Definitions

- **Completeness and Accuracy** - The completeness and accuracy of information contained within the EAE is reviewed / verified each time the EAE is used (e.g., reconciling control totals from source system to EAE).
- **Integrity & Logic** - Core logic, coding (e.g., formulas, parameters) and structure (e.g., references to data sources) of the EAE are reviewed each time the EAE is used
- **Access Restriction** - Access to the EAE is restricted through file-level password protection or access-controlled share drive (or similar, such as a MS SharePoint site)
- **Access Review** - Access to share drive locations (or similar) is reviewed for appropriateness at least annually
- **Versioning** - Naming conventions are utilized to clearly distinguish the current version of the EAE
- **Change Review** - Significant changes to EAE logic or coding are reviewed and approved
- **Backups** - EAEs are stored on share drive or SharePoint site (which are backed up by IT / Dell)

To facilitate documentation requirements for these controls an *optional* cover sheet and the “EAE Testing – Process Owner Guidance” has been provided within the Related Documents, Tools, and Templates section of this policy. The optional cover sheet should be used to document control requirements such as access restriction, change review, and completeness and accuracy for each EAE. Regardless as to whether or not the *optional* cover sheet is used, the process or control owner is responsible for maintaining evidence of the performance of the applicable controls and related reviews. When evidencing the review, more than a signature is needed in order to evidence the review; the evidence of the review should be clear as to what the review encompassed (e.g., what the reviewer looked at). The “EAE Testing – Process Owner Guidance” provides further information on control requirements and appropriate evidence; however, process owners should note that maintaining appropriate evidence of review will often depend on the nature of the control which may need to be assessed on a case by case basis by the process owner in order to comply with the policy.

DEFINITIONS

Term / Acronym	Definition
----------------	------------

Corporate, Owned & Leased Hotel Team Members	Corporate, Owned & Leased Hotel Team Members include team members in all corporate and regional offices and owned & leased hotel locations.
Process Owners	Process Owners are responsible for the design and operating effectiveness of internal controls within a process area affecting financial reporting.

ROLES AND RESPONSIBILITIES

Entity / Personnel	Responsibilities
Process Owner	- Documenting and maintaining a comprehensive and accurate inventory of key EAEs - Reviewing the inventory of key EAEs at a minimum quarterly and notifying the SOX PMO of any updates - Ensuring control activities are implemented, designed, documented, and operating effectively
SOX PMO	- Maintaining the inventory of EAEs and facilitating the annual inventory refresh, as part of annual SOX process updates and walkthroughs - Periodically assessing the design, implementation, and operating effectiveness of controls over EAEs
Policy Owner	- Ownership of this policy and related documents, tools, and templates - For questions refer to SOX_PMO@Hilton.com. <i>The email represents the SOX PMO contact address. Please direct any questions regarding the interpretation or implementation of this policy to the listed email.</i>

RELATED DOCUMENTS, TOOLS AND TEMPLATES

Tools / Templates	Location
Optional Cover Sheet	 Hilton - EAE Cover Sheet.xlsx
Process Owner Guidance:	 EAE Testing Process Owner Guidance.pdf

APPENDIX A: PRIORITIZATION DETAILS

Section	Criteria	Definition	Responses	Score
Significance	Proximity to Financials	A representation of how directly the EAE impacts the financial statements and line item.	Level 1 – Direct impact to F/S	9
			Level 2 – Indirect impact to F/S	3
			Level 3 – Minimal Impact to F/S	1
	Materiality	The dollar value of the impact an EAE may have on a financial statement	High – Impact greater than 40M	9
			Medium – Impact between 20M and 40M	3
			Low – Impact below 20M	1
Likelihood of Error	Frequency of Use	How often is the EAE utilized to produce information / figures	Daily	0
			Weekly	1
			Monthly	2
			Quarterly	3
			Annually	5
			Ad – Hoc	9
	Frequency of Logic Change	How often the structure or formulas within the EAE change	Daily	9
			Weekly	5
			Monthly	3
			Quarterly	2
			Semi-annually	1
			Annually	1
			Ad - Hoc	3
	Complexity	The level of intricacy and sophistication associated with the information and calculations within the EAE	High - External Data Pulls, Macros, etc.	9
			Medium - Translates and Reformats	3
			Low - Simple Calculator or Log	1
	Volume of Data and Transactions	The quantity of data and transactions processed by the EAE	High	9
			Medium	3
			Low	1

The above criteria are averaged to arrive at a calculated priority score, with proximity to financials weighted 20% greater than the other criteria. EAEs with scores of 5 or greater are considered high, scores between 3 and 5 are considered medium, and scores below 3 are considered low. Within the inventory, there is the option to override the calculated priority score with sufficient justification.